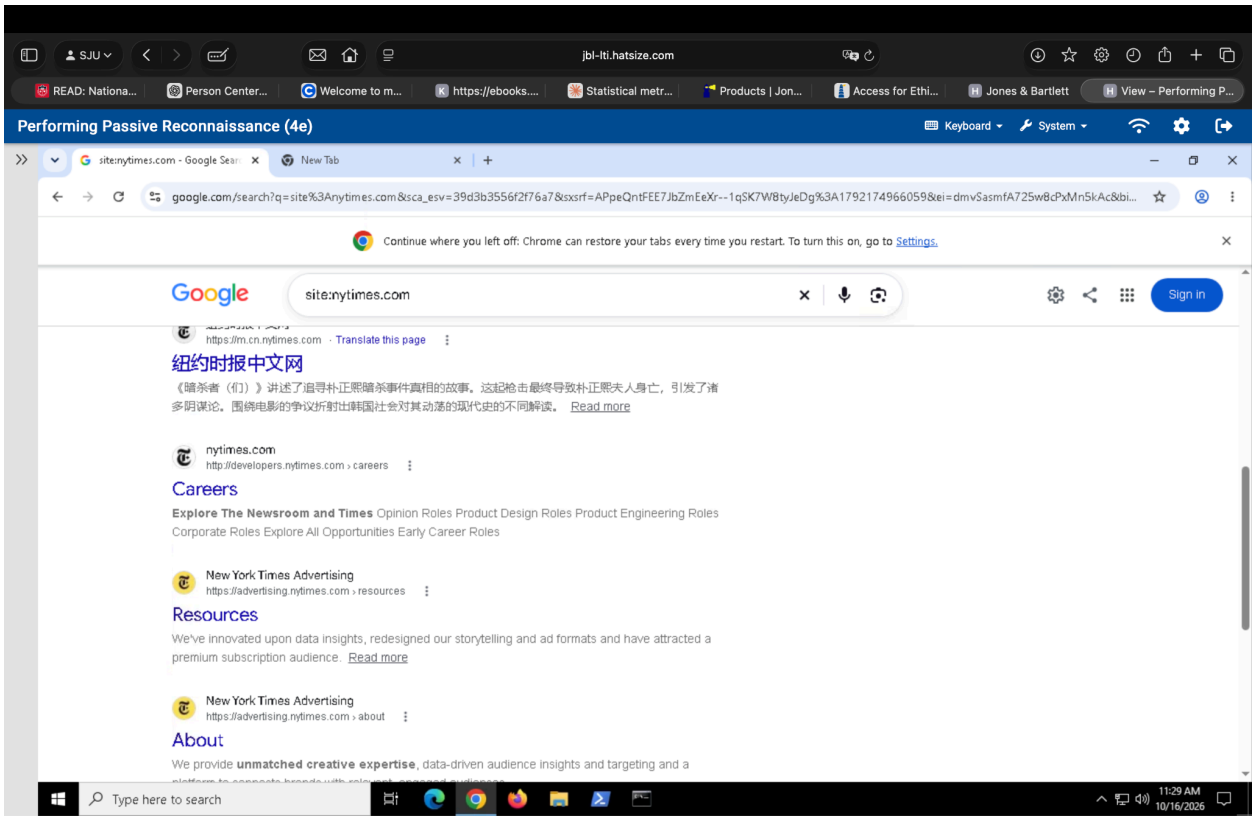
Saminur Karim

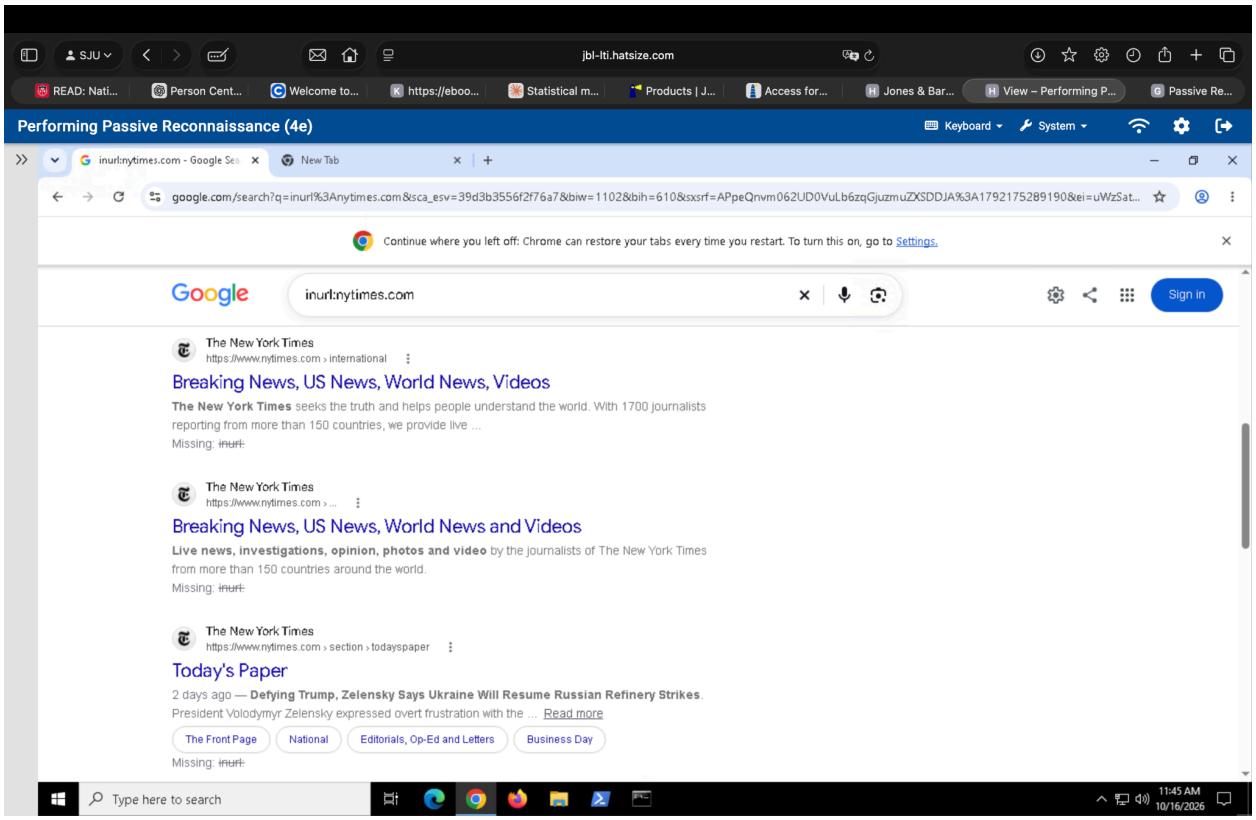
Passive reconnaissance is the act of gathering information about a target without using, notifying, or interactering with the target. In real-world environments, a hacker or threat actor may gather information using Open-Source Intelligence (OSINT) to formulate attacks against the user and systems. Passive reconnaissance is followed usually by active reconnaissance, where the threat actor probes and scans the systems identified through threat vectors. This lab covers and utilizes the following tools and sources:

- Use customized Google searches to conduct open-source intelligence gathering.
- Use Google's Advanced Search Operators to gather technical information about targets.
- Query Internet registration authorities for domain information.
- Use theHarvester to scrape information from public databases.
- Use Maltego to identify publicly available email addresses and domain names.

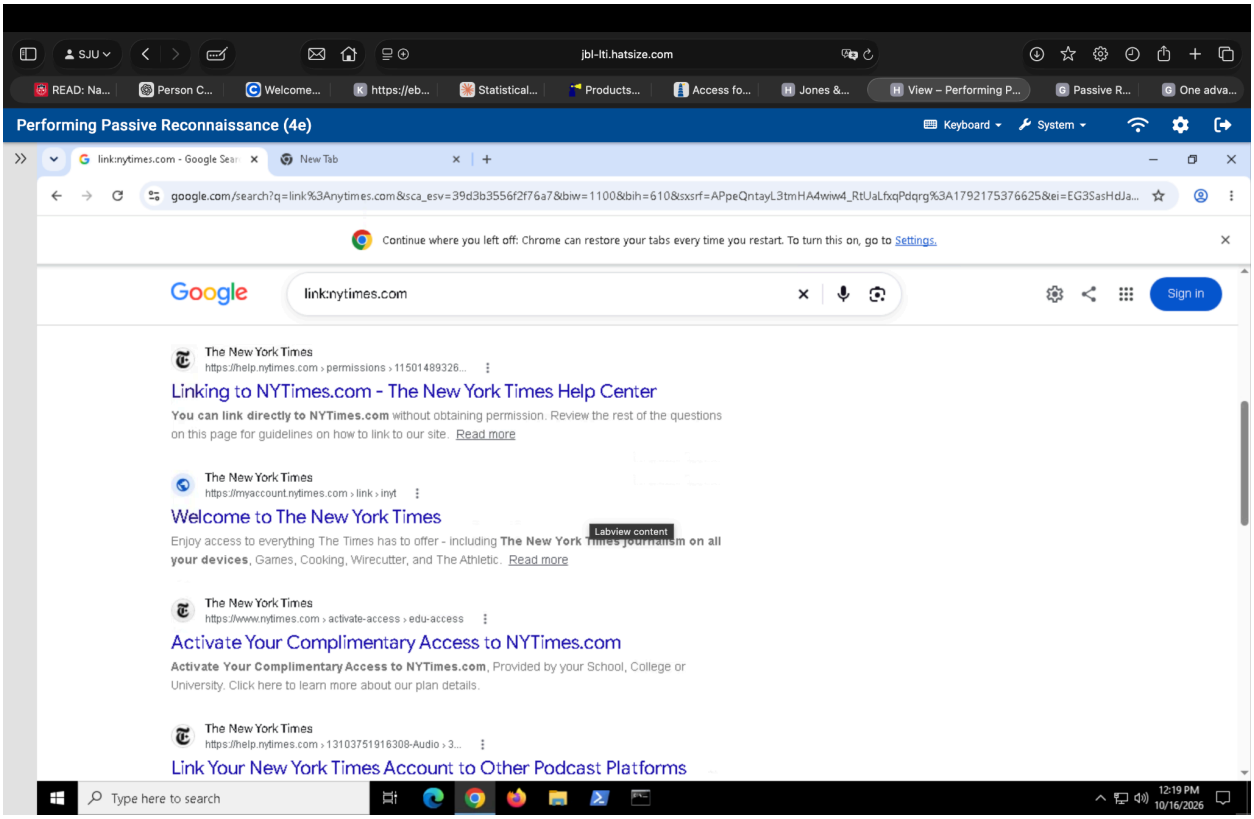
GoogleDorking The screenshot below shows a search for site:nytimes.com which limits searches to subdomains of nytimes.com. Results such as developers.nytimes.com and advertising.nytimes.com appear in the searches below as they are connected to the domain. The site operator restricts searches to a specific website, domain, or URL prefix.



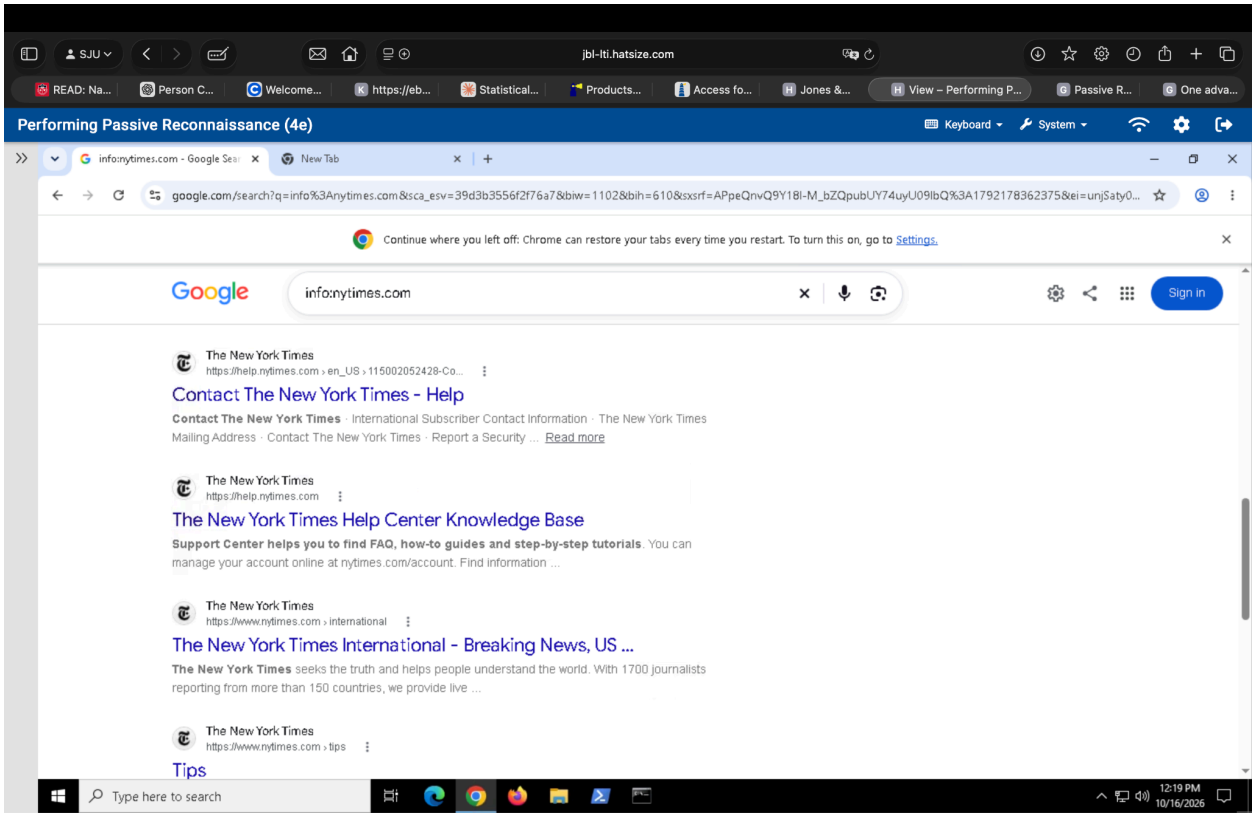
The screenshot below uses the inurl operator which finds subdirectories. The inurl operator can search within the URL for specific text and allows you to find specific names or paths on the internet.



The next search uses the link operator which finds pages linked to a specific domain or URL. The related operator finds sites related to a given domain.

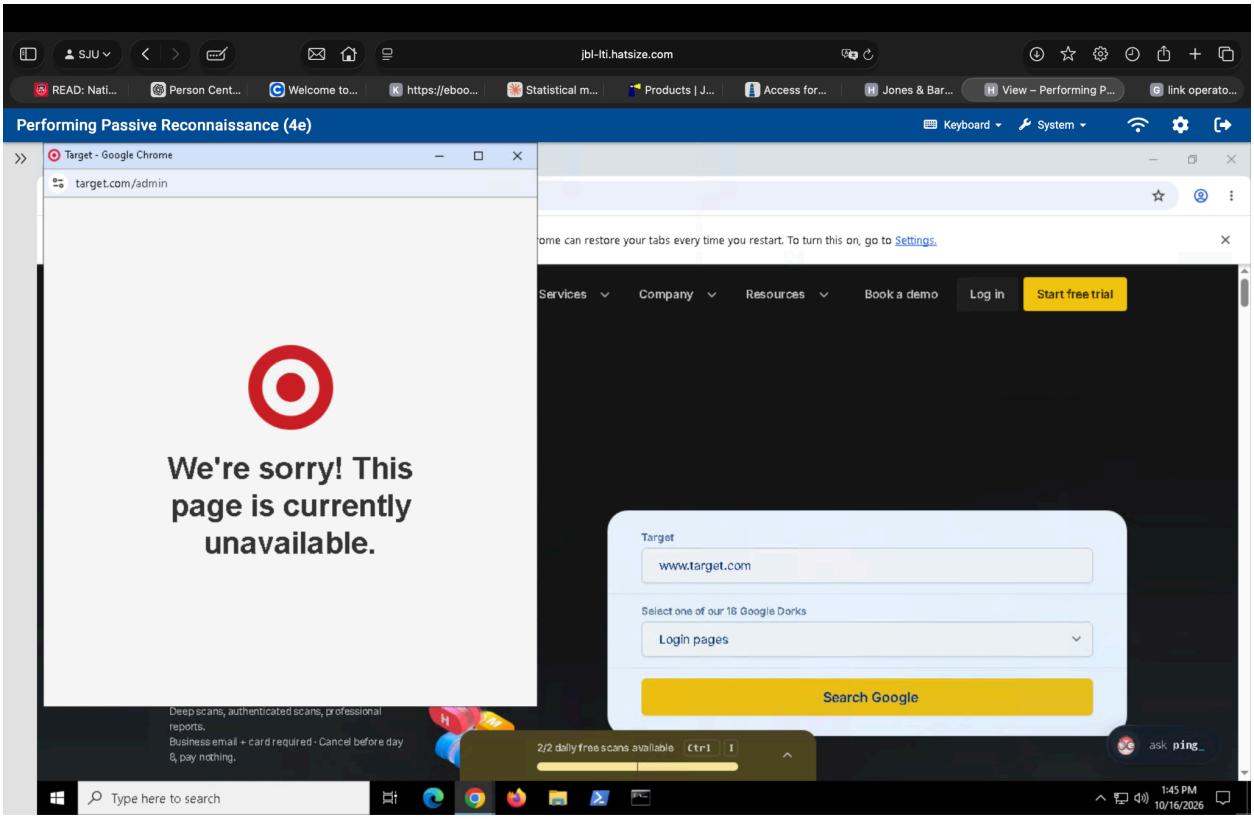


The operator info finds information about a specific page such as the most recent cache or similar pages.

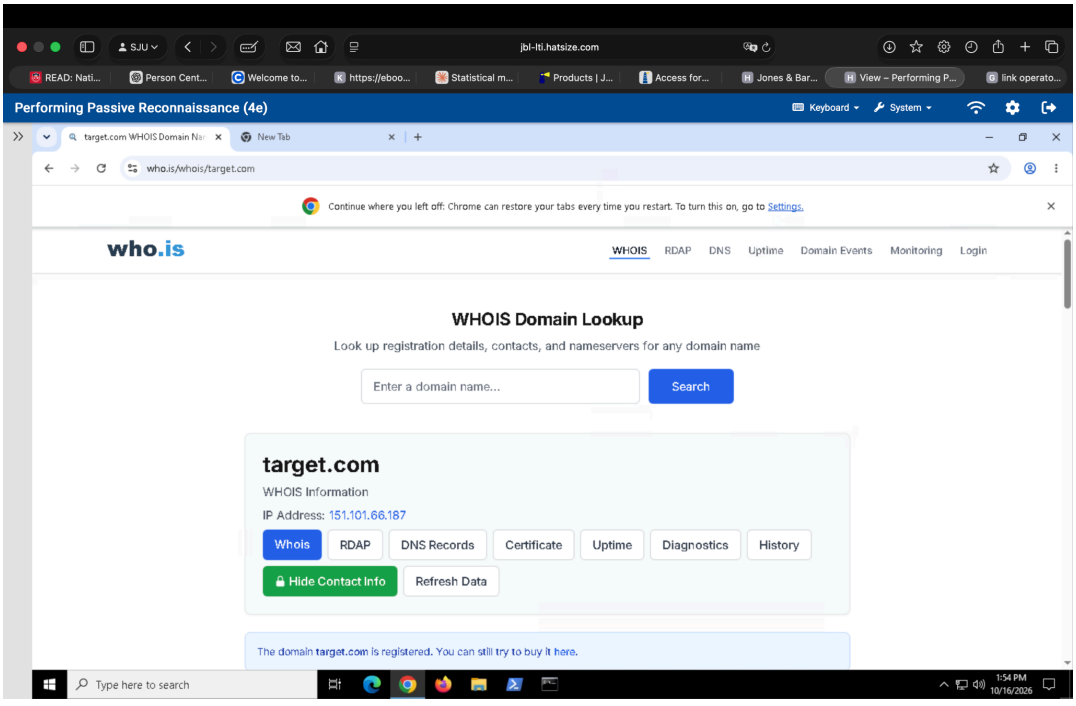


The link operator allows users to find specific pages linked to a domain or URL. This can gather information to search for 3rd party websites to visualize the attack surface or tracking leaked credentials and exposed data. The related operator finds sites related to information about a specific page. Identifying typosquatting and watering hole attacks are significant to target phishing campaigns against customers and their employees. The info operator finds specific information about a specific page. Finding bugs in configuration and accessing cached content that may contain API keys or company credentials are major vulnerabilities that a penetration tester can expose.

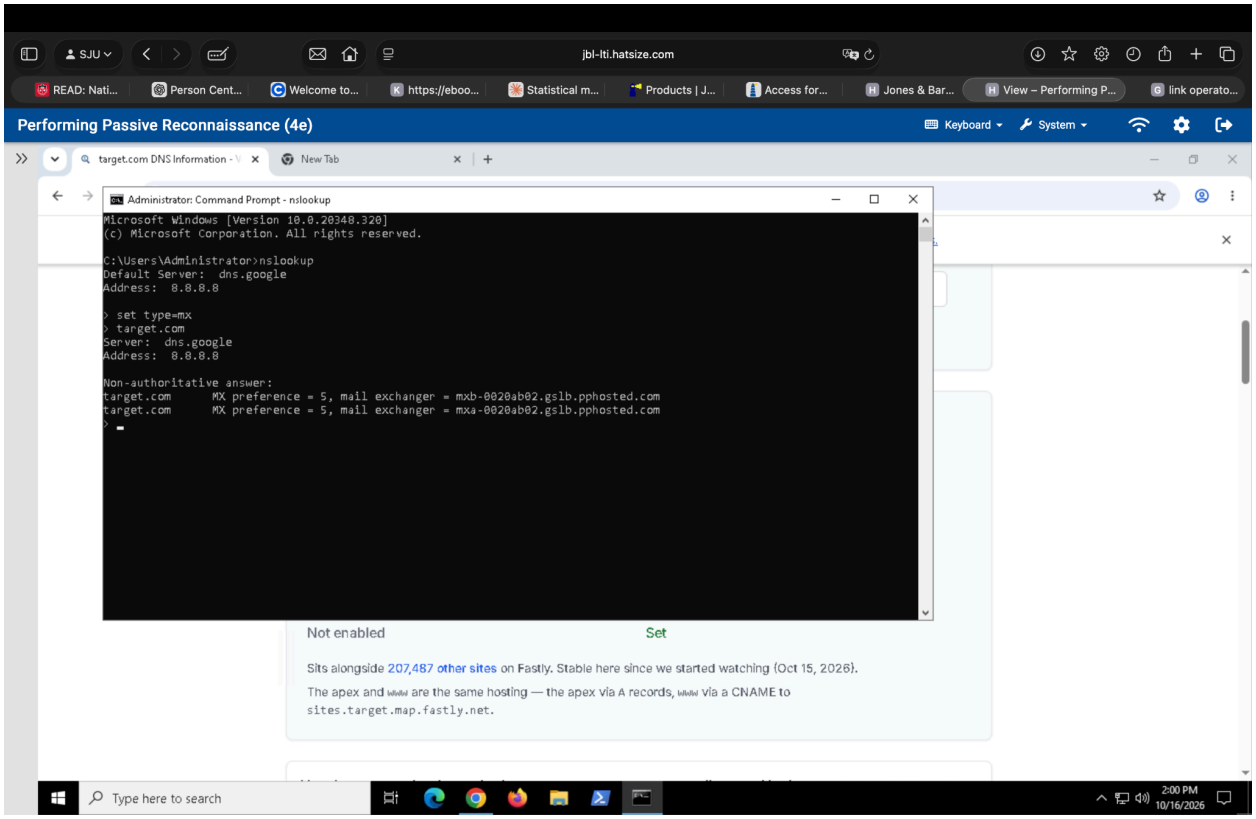
When using google hacking with pentesting.com against target.com, I was able to find an admin page. Exposed admin pages can be subject to SQL injections and stolen tokens that are intercepted in an MITM attack. Websites that aren't input sanitized can be manipulated with specific SQL queries.



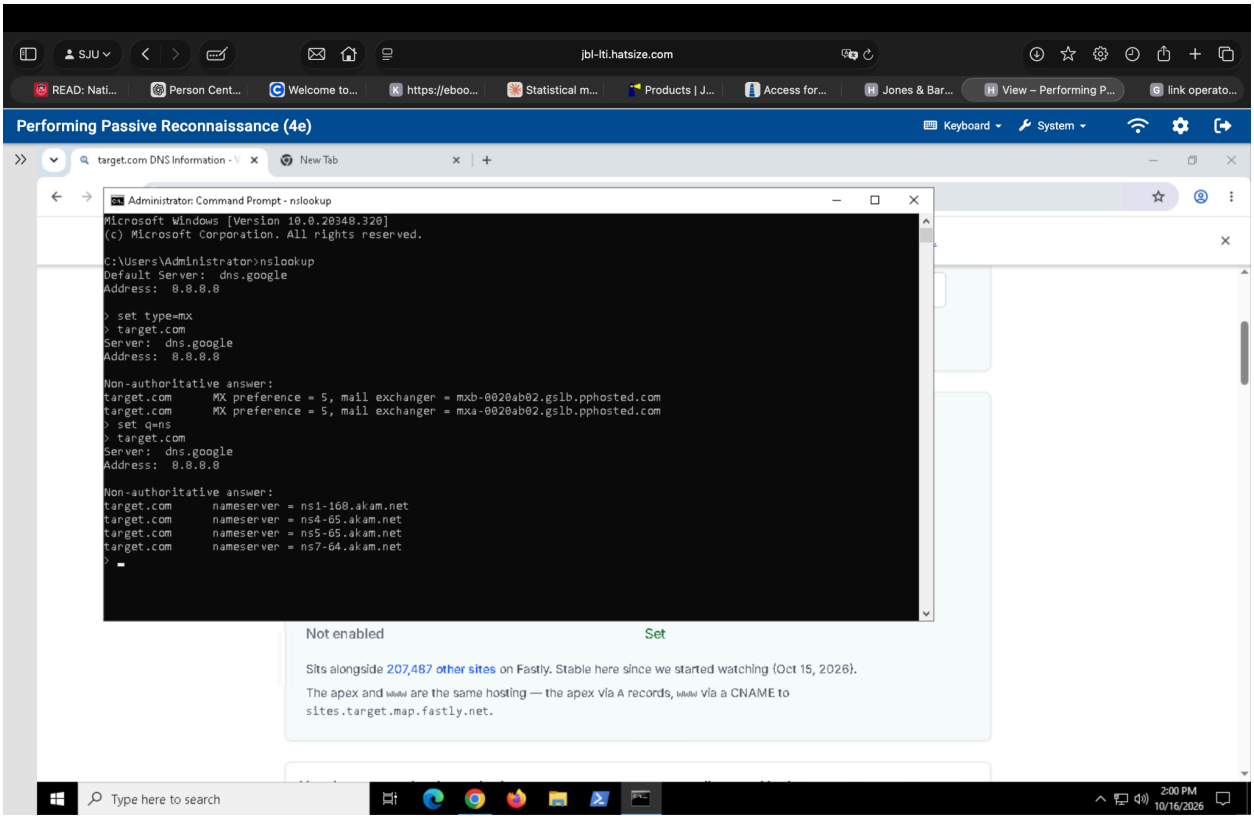
The website www.whois.com allows domain lookups with all information about a specific target. Queries can be sent to the databases to gather information about a website. In this case, I chose target.com and I was able to look at all DNS records, IP information, certificates and more.



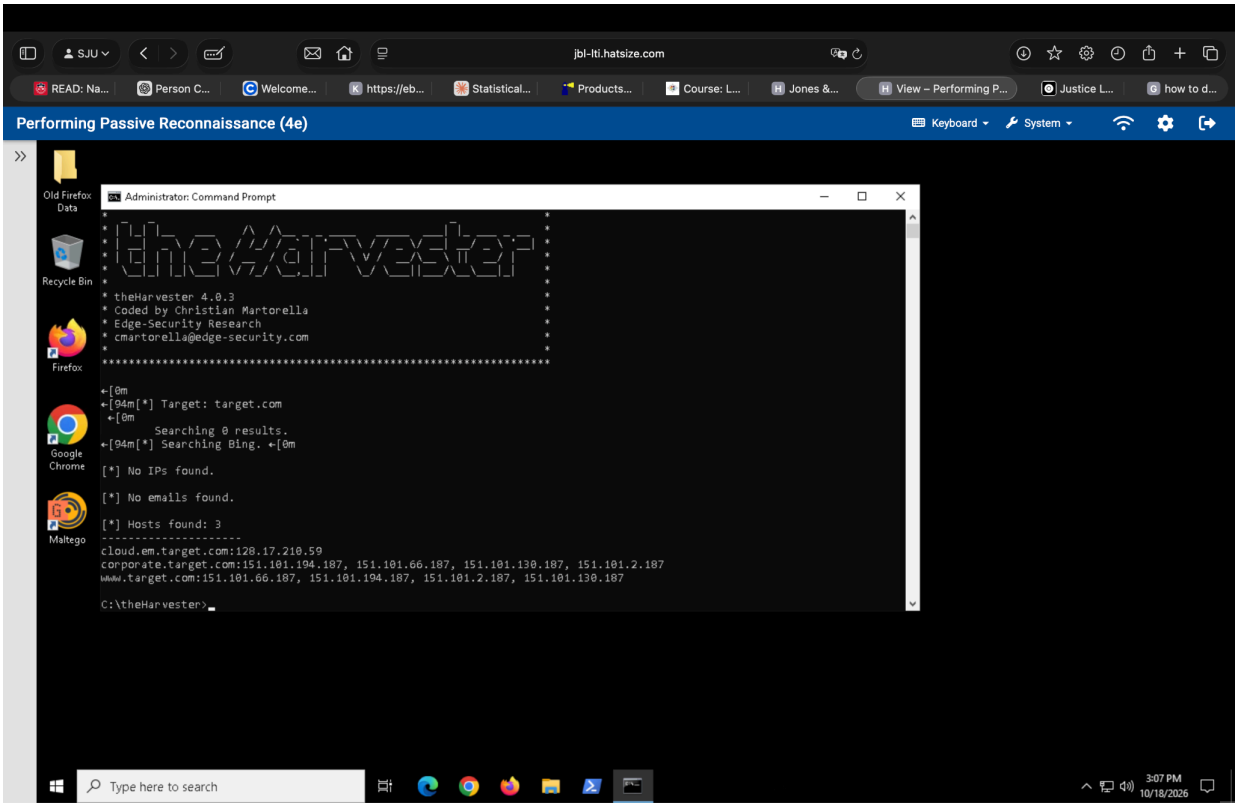
In the CLI, I used nslookup to query target.com for the MX or Mail Exchange records. The nslookup command showed my default server IP address to be 8.8.8.8 which is google.com. The information below showed target.com MX preference and mail exchanged websites.



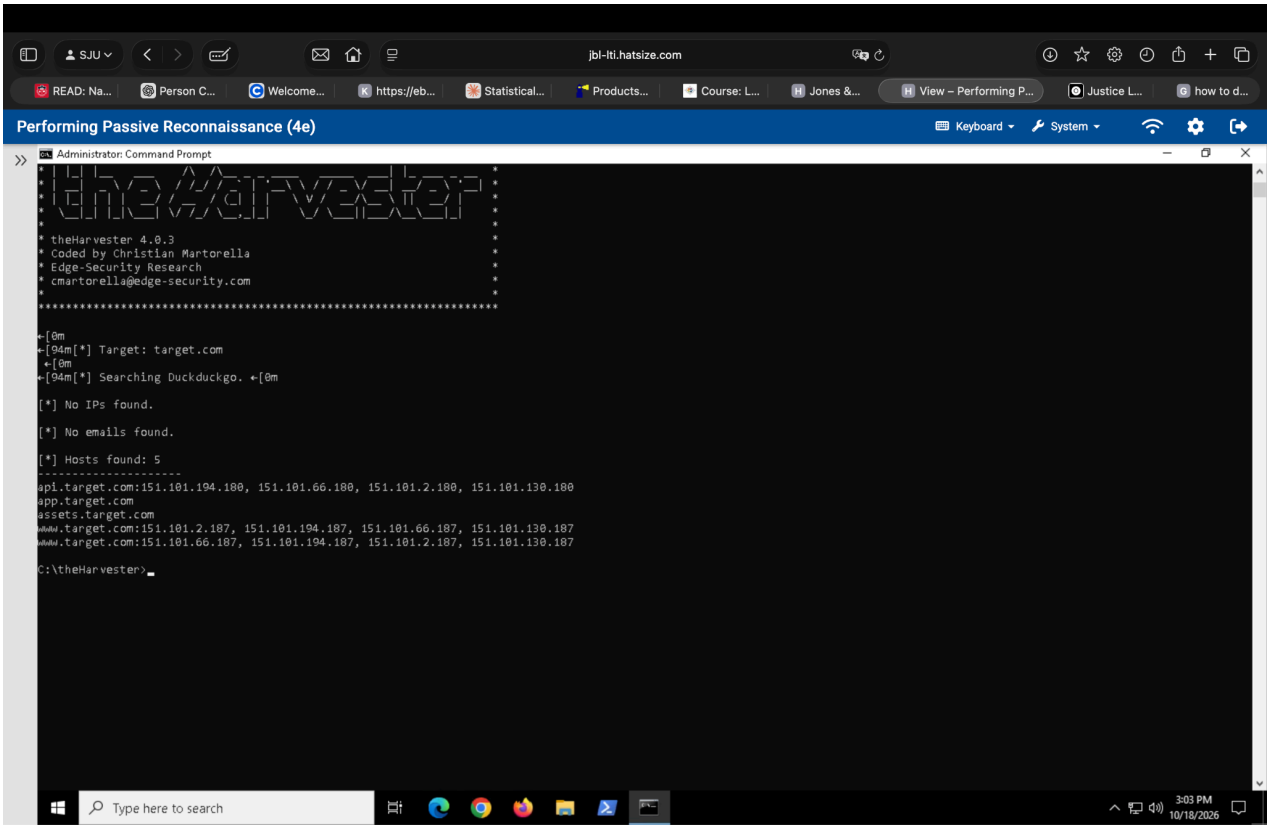
I used the command set type=ns to change the query to find authoritative servers for target.com. This showed all DNS servers for the specific website.



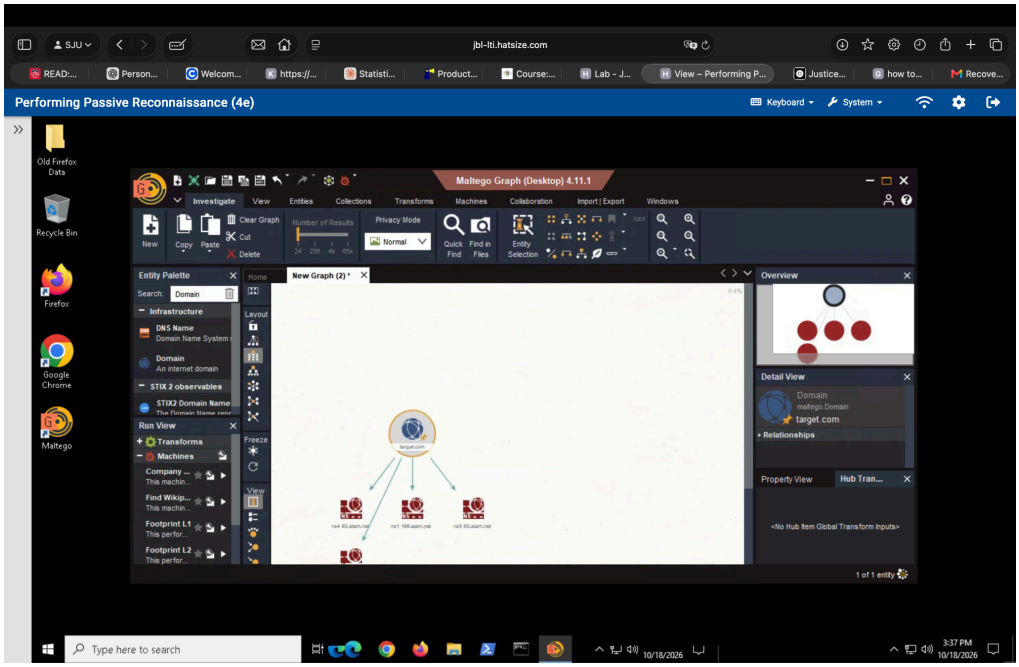
I then changed directories using the command **cd C:theHarvester**. Then, I opened theHarvesting using **theHarvester.py -h** which viewed the help guide for the tool. To collect information, I used the command **theHarvester.py -d target.com -b bing** to search for hosts, IP addresses, and email servers.

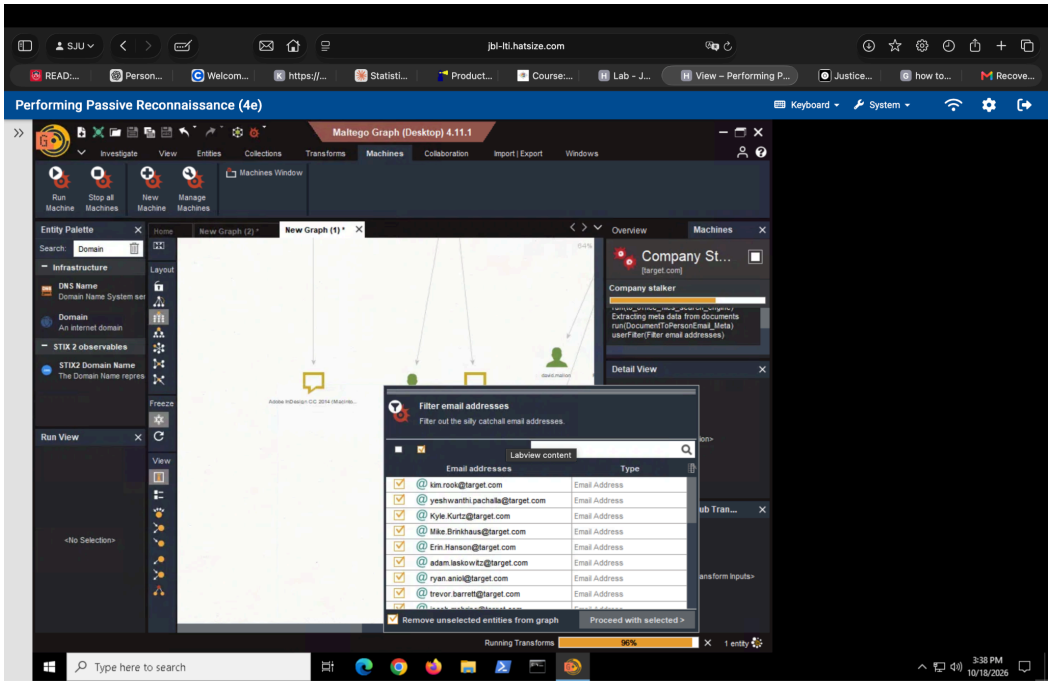


The same applied with a DuckDuckGo browser search.

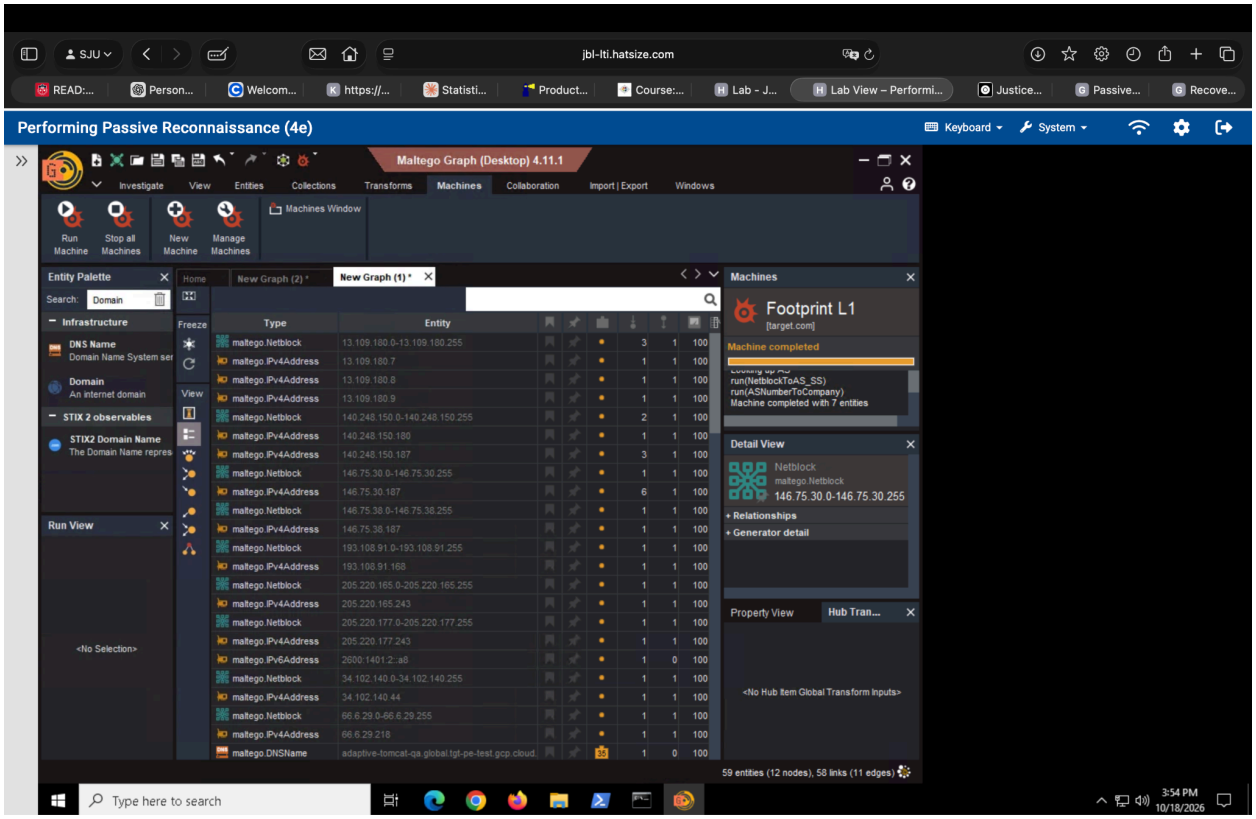


Maltego is another tool that gathers information about a domain like groups, the network, and information about the organization such as emails. I created a Maltego account and opened the app on my VM. I searched Domain in the entity palette searchbar and edited the Maltego domain to target.com. I filtered transformations to run the NS email server. Then, I navigated to the Machines toolbar and ran a machine to collect information about the domain. I ran the company stalker machine which collected information about employees including email addresses. This can be used for social engineering attacks like spear phishing and target specific users with brute force attacks.





This screenshot below displays DNS resolution and enumeration for a machine that completed a level 1 footprint of the target.com domain. This includes multiple phases including DNS enumeration, DNS resolution, ANS (Autonomous Number System) resolution. The final phase will identify the block that contains each IP address and the ASN for the ISP that has been allocated to that block.



Conclusion and Lessons Learned:

This lab reinforced how much actionable intelligence can be gathered about a target before ever sending a single packet to its systems. Using only Google dorking operators (site, inurl, link, related, info), I was able to map out subdomains, locate an exposed admin page on target.com, and identify potential entry points for SQL injection or credential interception, all without interacting directly with the target. WHOIS lookups and nslookup then filled in the infrastructure picture: DNS records, MX servers, and authoritative name servers that a threat actor could use to plan DNS spoofing, mail server attacks, or identify hosting providers. theHarvester and Maltego extended this further by automating the collection of email addresses, subdomains, and employee information across multiple search engines, showing how quickly an attacker can build a target list for spear phishing or credential-stuffing campaigns from publicly available data alone.

The biggest lesson from this lab is that passive reconnaissance is not a minor preliminary step, it is often the phase that determines whether an attack succeeds. A single exposed admin panel, an unsanitized input field, or a scraped employee email list can give an attacker everything they need to move into active reconnaissance or exploitation. From a defensive standpoint, this lab highlighted several real takeaways for a future SOC analyst: organizations should regularly audit what Google indexes about their own domains, restrict or monitor access to admin interfaces, limit how much employee contact information is publicly discoverable, and treat DNS and WHOIS records as information that should be minimized wherever possible. Seeing how fast tools like theHarvester and Maltego assembled a profile of a domain also underscored why employee security awareness training, particularly around phishing and social engineering, is such a critical control, since so much of what these tools surface is exactly what a phishing pretext is built from.

Overall, this lab gave me a practical understanding of the OSINT techniques threat actors rely on and, just as importantly, the defensive gaps they exploit, which directly connects to the kind of detection and monitoring work I want to do as a SOC analyst.